

Papillon

Yapay Zekâ Destekli Siber Güvenlik Platformu

Proje Kısıt ve Etkiler Raporu (PKE-Rapor)

Ders: BİL496 — Bitirme Projesi

Kurum: TOBB Ekonomi ve Teknoloji Üniversitesi

Bölüm: Bilgisayar Mühendisliği

Hazırlayanlar:

- Kerem Elma - 211101079
- Mehmet Eski - 221104095
- Mete Cem Turan - 211101054
- Sabri Mert Pişkin - 211101035

Github Repository: <https://github.com/SabriMertPiskin/Papillon>

Bahar 2025–2026

1. Standartlara Uyum Özeti

Papillon projesi, yazılım mühendisliği yaşam döngüsü boyunca aşağıdaki IEEE ve endüstri standartlarına uygun olarak geliştirilmiştir.

1.1 Uyulan Mühendislik Standartları

Standart	Açıklama	Durum	Kanıt Referansı
IEEE 830 (SRS)	Yazılım Gereksinim Spesifikasyonu	Uyumlu	IEEE_SRS v2.0; 11 fonksiyonel gereksinim (FR1-FR11) tanımlanmış
IEEE 1016 (SDD)	Yazılım Tasarım Dokümanı	Uyumlu	IEEE_SDD v1.1; üç katmanlı mimari, 11 Django app, DB şeması
IEEE 829 (STP)	Yazılım Test Planı	Uyumlu	IEEE_STP v1.0; 9 test senaryosu, 270 test vakası, %100 geçme
IEEE 1058 (PMP)	Proje Yönetim Planı	Uyumlu	IEEE_PMP v2.0; 5 sprint, Gantt, toplantı tutanakları
IEEE 730 (QMP)	Kalite Yönetim Planı	Uyumlu	IEEE_QMP v1.0; kod gözden geçirme, Final Quality Model
IEEE 1471 (SAD)	Yazılım Mimari Dokümanı	Uyumlu	IEEE_SAD v1.0; sistem görünümleri, bileşen ilişkileri
OWASP Top 10	Web Uygulama Güvenliği	Uyumlu	RBAC, CSRF, session, AES-256-GCM, 270 test
NIST FIPS 197	AES Şifreleme Standardı	Uyumlu	crypto/ modülü; AES-256-GCM, 256-bit anahtar, TC-09
RFC 8017 (RSA)	RSA Kriptografi	Uyumlu	crypto/ modülü; RSA-2048, PEM serileştirme, TC-09
RFC 6238 (TOTP)	Zaman Tabanlı OTP	Uyumlu	users/ modülü; MFA, QR kod, TOTP doğrulama, TC-12
KVKK / GDPR	Kişisel Verilerin Korunması	Kısmi Uyum	On-premises; 3. taraf aktarım yok. Resmi denetim yapılmadı
ISO/IEC 25010	Yazılım Kalite Modeli	Kısmi Uyum	Final Quality Model hazır
ISO/IEC 27001	BGYS	Uygulanamaz	Akademik ortam; kurumsal sertifikasyon kapsam dışı

1.2 Standart Uyum Özet İstatistikleri

Durum	Sayı	Yüzde
Uyumlu	10	%76,9
Kısmi Uyum	2	%15,4
Uygulanamaz	1	%7,7
Toplam	13	%100

1.3 Kanıt Belgeleri Dizini

Belge	İçerik	Tarih
IEEE SRS v2.0	Yazılım gereksinim spesifikasyonu	18.11.2025
IEEE SDD v1.1	Yazılım tasarım dokümanı	30.11.2025
IEEE STP v1.0	Yazılım test planı	27.11.2025
IEEE PMP v2.0	Proje yönetim planı (5 sprint)	15.12.2025
IEEE QMP v1.0	Kalite yönetim planı	08.11.2025
IEEE SAD v1.0	Yazılım mimari dokümanı	09.11.2025
PKE-Plan	Kısıt ve etki tanımları	07.11.2025
Final Quality Model	Kalite modeli ve ölçüm sonuçları	13.12.2025
Quality Metrics	Kalite metrikleri raporu	13.12.2025

Test Plan Report v1	Detaylı test sonuçları	15.03.2026
Sprint 1-5 Raporları	Her sprint için ilerleme raporları	2025
Toplantı Tutanakları	Sprint toplantı tutanakları (5 adet)	2025

2. Kısıtların Yönetimi Özeti

PKE-Plan'da tanımlanan kısıtlar, fiilen yapılanlar, sapmalar ve risk/kapsam değişiklikleri.

2.1 Teknik Kısıtlar

Kısıt	Planlanan Çözüm	Fiilen Yapılan	Sonuç / Sapma
AI Model Boyutu (~600 MB)	Lazy loading ile bellek optimizasyonu	LazyModelLoader sınıfı; modeller ilk istek anında yükleniyor	Sapma yok. Başlangıç süresi minimize edildi.
Veritabanı Ölçeklenebilirliği	Geliştirmede MySQL	MySQL kullanıldı	Kısmi sapma: Üretim geçişi yapılmadı (akademik kapsam).
NVD API Hız Limiti	API anahtarı ile hız sınırı aşımını önleme	API anahtarsız; 5 istek/30 sn limiti kabul edildi	Kısmi sapma: Yoğun kullanımda gecikme olabilir.
Outlook OAuth Gereksinimi	Azure AD kaydı; OAuth 2.0 akışı	MSAL ile tam OAuth 2.0 uygulandı; Azure AD tamamlandı	Sapma yok. Manuel test ile doğrulandı.
Çapraz Platform Uyuml.	SPA mimarisi ile tarayıcı bağımsızlığı	React 18 + Vite ile responsive SPA geliştirildi	Sapma yok. Chrome, Firefox, Edge test edildi.
AI Model Doğruluğu	Phishing E-mail Dataset, Password Strength Dataet, EMBER ile eğitilmiş modeller	3 model entegre edildi; mock testlerle doğrulandı	Sapma: Gerçek üretim performansı değerlendirilemedi.

2.2 Kaynak ve Zaman Kısıtları

Kısıt	Planlanan Çözüm	Fiilen Yapılan	Sonuç / Sapma
Proje Süresi (2 dönem)	5 sprint planlaması; Gantt şeması	5 sprint tamamlandı	Sapma yok.
Tek Geliştirici	Modüler mimari	12 Django app + 24 React bileşeni oluşturuldu	Sapma yok. Modüler yapı verimliliği sağladı.
GPU Kaynağı Yokluğu	Hafif ML algoritmaları seçimi	scikit-learn, ONNX Runtime	Sapma yok.
Bütçe Kısıtı	Açık kaynak teknolojiler; ücretsiz API'ler	Django, React, tamamı açık kaynak	Sapma yok. Lisans maliyeti sıfır.

2.3 Yasal ve Etik Kısıtlar

Kısıt	Planlanan Çözüm	Fiilen Yapılan	Sonuç / Sapma
KVKK/GDPR	On-premises mimari; verilerin yerel işlenmesi	Tüm analiz yerel sunucuda; 3. taraf buluta veri yok	Sapma yok.
Şifreleme Standartları	NIST onaylı algoritmalar (AES-256, RSA-2048)	cryptography kütüphanesi ile FIPS 197 + RFC 8017	Sapma yok.
Açık Kaynak Lisanslama	Lisans uyumluluk kontrolü	MIT, BSD, Apache 2.0 — tümü uyumlu doğrulandı	Sapma yok.

2.4 Risk ve Kapsam Değişiklikleri

- Outlook Modülü Otomatik Test Eksikliği:** OAuth canlı token gereksinimleri nedeniyle otomatik test yazılamadı. Manuel test ile doğrulandı.
- Üretim Dağıtımı Ertelendi:** Docker/Kubernetes dağıtımı gelecek çalışmalar olarak planlandı.
- CI/CD Kısıtlı Kaldı:** 600 MB+ AI model dosyaları nedeniyle CI/CD'de tam model yüklemeli test yapılamadı; mock testlerle ikame edildi.
- Network Intrusion Detection Modülü:** CICIDS2017 veri seti ile eğitilen Network Intrusion Detection modeli hazır hale getirilmiştir. Ancak, modele uygun formatta trafik verisi sağlayacak

CICFlowMeter modülü entegre edilemediği için model canlı ortamda kullanılamamıştır. Bu nedenle elde edilen trafik verisi üzerinde teknik analiz yapılmıştır.

2.5 Öğrenimler ve Sonuçlar

- **Modüler mimari:** Kısıtların etkisini izole etmede kritik. 12 bağımsız Django app sayesinde bir modüldeki kısıt diğerlerini etkilemedi.
- **Lazy loading:** Büyük AI model dosyalarının bellek yönetiminde etkili çözüm oldu.
- **Açık kaynak ekosistemi:** Bütçe kısıtını tamamen ortadan kaldırdı.
- **Sprint bazlı planlama:** Zaman kısıtının yönetiminde belirleyici oldu.
- **Standart tabanlı geliştirme:** (IEEE 830, 1016, 829, 1058, 730) dokümantasyon kalitesini artırdı.

3. Beklenen ve Gerçekleşen Etki Sonuçları

PKE-Plan'da tanımlanan beklenen etkiler ile gerçekleşen etkiler karşılaştırmalı olarak sunulmaktadır.

3.1 Ekonomik Etkiler

No	Beklenen Etki	Gerçekleşen Etki
E1	Ticari platformların (Splunk, CrowdStrike) 50K-500K\$ lisans maliyetine karşı %90+ maliyet düşürme	Gerçekleşti. Tamamen açık kaynak; lisans maliyeti sıfır. IDS, malware, phishing, zafiyet tek platformda.
E2	Güvenlik analistlerinin bağlam değiştirme yükünü azaltarak verimlilik artışı	Kısmen gerçekleşti. Birden fazla araç yerine tek dashboard. AI ile MTTD saniyeler mertebesine indi.
E3	KOBİ'lerin uygun maliyetli güvenlik izlemesi yapabilmesi	Potansiyel. Platform teknik olarak hazır, ancak üretim dağıtımı yapılmadı.

3.2 Sosyal Etkiler

No	Beklenen Etki	Gerçekleşen Etki
S1	Siber güvenlik farkındalığını artırma (parola gücü eğitimi)	Gerçekleşti. Password Strength modülü entropi, karakter analizi ve yaygın parola uyarıları ile eğitici geri bildirim sunuyor (35 test).
S2	Kritik altyapılarda (hastane, okul, belediye) uygun maliyetli güvenlik	Potansiyel. IDS ve zafiyet yönetimi hazır, ancak kurumsal dağıtım yapılmadı.
S3	Gelişmekte olan ülkelerde siber güvenlik erişimini demokratikleştirme	Kısmen gerçekleşti. Açık kaynak + sıfır lisans. NVD API ile coğrafyadan bağımsız zafiyet istihbaratı.

3.3 Çevresel Etkiler

No	Beklenen Etki	Gerçekleşen Etki
Ç1	Birden fazla güvenlik cihazı yerine tek platform ile enerji/donanım tasarrufu	Gerçekleşti. 12 modül tek Django sürecinde. MySQL ile minimum kaynak.
Ç2	Hafif ML modelleri ile GPU gereksinimini ortadan kaldırma	Gerçekleşti. scikit-learn, ONNX Runtime
Ç3	Bulut-opsiyonel tasarım ile gereksiz karbon ayak izi önleme	Gerçekleşti. Temel işlevler on-premises; AWS yalnızca VM Lab için opsiyonel.

3.4 Hukuki Etkiler

No	Beklenen Etki	Gerçekleşen Etki
H1	GDPR/KVKK uyumluluğunu destekleme	Kısmen gerçekleşti. Veriler yerel, AES-256-GCM + MFA uygulanıyor. Resmi denetim yapılmadı.
H2	Saldırı yüzeyi tarama ile açık veri uç noktalarını tespit etme	Gerçekleşti. Attack Surface: DNS, SSL, subdomain, port, WHOIS (33 test).
H3	Açık kaynak lisans uyumluluğu	Gerçekleşti. MIT, BSD, Apache 2.0 — tümü doğrulandı.

3.5 Sağlık ve Güvenlik Etkileri

No	Beklenen Etki	Gerçekleşen Etki
SG1	Veri gizliliğinin korunması (kullanıcı bilgi güvenliği)	Gerçekleşti. AES-256-GCM şifreleme, RBAC erişim kontrolü, TC-04'te sıfır yetki yükseltme.
SG2	Fidye yazılımına karşı erken uyarı	Gerçekleşti. Malware Analysis: dosya değerlendirme (27 test).
SG3	Phishing saldırılarından korunma	Gerçekleşti. ONNX tabanlı model, semantik kalıp analizi ile AI-üretimli phishing'e dayanıklı (28 test).

3.6 Etki Sonuçları Özet Tablosu

Kategori	Beklenen	Gerçekleşen	Genel Değerlendirme
Ekonomik	3	1 tam, 1 kısmi, 1 potansiyel	Maliyet düşürme hedefi karşılandı
Sosyal	3	1 tam, 1 kısmi, 1 potansiyel	Farkındalık sağlandı; dağıtım yapılmadı
Çevresel	3	3 tam	Tüm hedefler karşılandı
Hukuki	3	2 tam, 1 kısmi	Teknik altyapı hazır; denetim yok
Sağlık/Güvenlik	3	3 tam	Tüm hedefler karşılandı ve test edildi
Toplam	15	10 tam, 3 kısmi, 2 potansiyel	Genel başarı: %86,7 (tam+kısmi)

3.7 Kanıtlar ve Metrikler

- Test Sonuçları:** 244 otomatik test vakası, %100 geçme oranı, 10/11 FR kapsandı (TC-01 – TC-12).
- RBAC Güvenlik Kanıtı:** TC-04'te 3 ardışık yetki yükseltme denemesinin tamamı reddedildi.
- Şifreleme Doğrulaması:** AES-256-GCM ve RSA-2048 roundtrip testleri, nonce benzersizliği, yanlış anahtar reddi (TC-09, 27 test).
- AI Model Doğrulaması:** 4 model entegrasyonu; zararsız→düşük skor, zararlı→yüksek skor doğrulandı (TC-01, TC-02, TC-03, TC-11).
- Modül Tamamlanma:** 16/16 modül (%100). Backend (11 Django app) + Frontend (16 sayfa) + AI (3 model).
- Kod Tabanı:** 26 REST API endpoint, 6 DB model, 14 CSS dosyası (~140 KB), 50+ git commit.
- Sprint İzleme:** 5 sprint başarıyla tamamlandı; her sprint için rapor ve tutanak hazırlandı.
- Kalite Metrikleri:** Final Quality Model ve Quality Metrics raporları ile kalite ölçülüp belgelendi.

Kaynaklar

- [1] IEEE 830-1998, IEEE Recommended Practice for Software Requirements Specifications, IEEE, 1998.
- [2] IEEE 1016-2009, IEEE Standard for Information Technology — Software Design Descriptions, IEEE, 2009.
- [3] IEEE 829-2008, IEEE Standard for Software and System Test Documentation, IEEE, 2008.
- [4] IEEE 1058-1998, IEEE Standard for Software Project Management Plans, IEEE, 1998.
- [5] IEEE 730-2014, IEEE Standard for Software Quality Assurance Processes, IEEE, 2014.
- [6] IEEE 1471-2000, IEEE Recommended Practice for Architectural Description, IEEE, 2000.
- [7] OWASP Foundation, OWASP Top 10 — 2021, <https://owasp.org/www-project-top-ten/>, 2021.
- [8] NIST, FIPS PUB 197: Advanced Encryption Standard (AES), 2001.
- [9] K. Moriarty et al., PKCS #1: RSA Cryptography Specifications v2.2, RFC 8017, 2016.
- [10] D. M'Raihi et al., TOTP: Time-Based One-Time Password Algorithm, RFC 6238, 2011.
- [11] NIST, National Vulnerability Database API 2.0, <https://nvd.nist.gov/developers/>, 2024.
- [12] T. Chen and C. Guestrin, XGBoost: A Scalable Tree Boosting System, KDD, 2016.
- [13] H.S. Anderson and P. Roth, EMBER: An Open Dataset for Training Static PE Malware ML Models, AAAI, 2018.
- [14] F. Pedregosa et al., Scikit-learn: Machine Learning in Python, JMLR, vol. 12, 2011.
- [15] I. Sharafaldin et al., Toward Generating a New Intrusion Detection Dataset, ICISSP, 2018.
- [16] World Economic Forum, Global Risks Report 2025, 2025.
- [17] IBM Security, Cost of a Data Breach Report 2024, 2024.
- [18] Kişisel Verilerin Korunması Kanunu (KVKK), Kanun No. 6698, Türkiye, 2016.
- [19] General Data Protection Regulation (GDPR), Regulation (EU) 2016/679, EU, 2016.
- [20] ISO/IEC 25010:2011, Systems and Software Quality Requirements and Evaluation (SQuaRE), ISO, 2011.